

Q6. What key strengths have you experienced when using the tool?

It helps to address some of the most challenging issues faced by cyber security professionals today, such as needing to prioritize the huge volumes of vulnerabilities by taking into account both the threat actors' perspectives as well as the defensive measures in place. The ability to analyze images of architectural diagrams to produce reasonably accurate assessments of possible attack paths automatically is a strong plus especially when aided by a SME perspective.

A structured and unbiased processes for system of systems risk assessment.

Ability to deduce and decompose system components from various forms of inputs.

Modelling of future risks across the system when a fix is applied.

LLM is able to read my architecture diagram without much "manual" input of the description. This is extremely useful when we have complex architectures and architecture owners does not provide much information about it (e.g. missing description of certain data flows and etc).

Ability to map out the contextualised attack path based on APT group and prioritized set of defensive measures based on the ingestion of architecture diagrams.

What stood out most to me was how quickly the tool could generate a structured view of the system just from an architectural diagram. It identified the key components, trust boundaries, and attack entry points quite intuitively — the kind of groundwork that usually takes time to piece together manually.

I also liked how the workflow links each step together — from the architecture breakdown to STRIDE-LM, then to DREAD and the attack tree. It makes the process feel coherent and guided, rather than having to switch across different tools or frameworks.

Overall, I see it as a strong “first-cut” tool that helps kickstart threat and risk assessments. Instead of starting from scratch or referencing old templates, this gives a quick and structured baseline to work from, especially useful when assessments are a regular part of the work.

User-friendly and adaptable

Very good tool for giving me the first cut, and as a check against what I have in mind... makes it a lot more efficient

The tool use a statistical risk calculation, by putting a number into a scale of risk severity. This is very useful to cybersecurity professional to triage. The tool also use an attacker path which is an advanced methodology, as attackers think like graph but the usual defender or compliance team think like list (checklist).

I particularly like the design of the tool using AI to analyse architecture, which is useful for cyber professional. If utilized correctly, this tool can perform TRA, and benefit IT counterpart to implement secure by design.

The flexibility to have different LLMs and models to select

A step by step guide for the user to analyse the threat landscape

Downloadable actionable files for other integration usage

1. It gave very useful information to understand the component in a typical OT Architecture diagram, threat, risk and attack path, this can save a lot of time to gather information from different sources.
2. It didn't work when i uploaded my own architecture diagram, the information generated was related to a typical OT architecture where my diagram has nothing related to OT. If the LLM works by giving data relating to the architecture diagram i have uploaded, it will definitely be useful.

Leveraging on the existing models

Considerations given on the scope of coverage of attack surface

The tool demonstrates a comprehensive and methodical framework for asset management and risk assessment. By enabling users to systematically identify and categorise assets into distinct zones and conduits, it lays a solid foundation for understanding the security landscape. The utilisation of the STRIDE-LM model to pinpoint threats ensures that a wide spectrum of potential issues is considered, covering various threat categories. Translating these threats into tangible risks adds clarity and relevance, making it easier for stakeholders to comprehend the implications. The tool's capability to generate viable attack paths further enhances its value, as it provides actionable insights into how vulnerabilities might be exploited. Finally, the quantification of control effectiveness in reducing risk is particularly noteworthy, as it supports more informed and efficient resource allocation. Overall, the tool appears to offer a robust and logical approach to risk management, supporting both strategic planning and operational security improvements.

Q7. What limitations or challenges have you encountered while using the tool?

The need to adjust different permutations of probabilities, which can be too time consuming and theoretical.

inconsistent outcomes.

Limited ability to shape the start state.

Information overload/unattractive data presentation.

No doubt, I still need to verify to make sure that the information generated by LLM is factual and possible. But i believe this can be improved over iterations of improvement and once the LLM gives a higher level of confidence, the manual verification can be reduced.

Mapping against MITRE ATT&CK and DEF3ND would be useful. There are some bugs that may need further ironing out. human-in-the-loop is still inevitable at this point.

One area I'd like to see strengthened is the transparency behind the DREAD scoring. For practitioners, it helps to understand how each score is derived — for example, what drives the reproducibility or exploitability rating. In real-world assessments, we often anchor our evaluations to known cases or credible scenarios. For instance, when an HMI compromise blinds an operator's view of system status — as seen in the Stuxnet incident — the impact and exploitability become tangible rather than theoretical. That kind of traceability builds confidence in the assessment and makes it easier to defend the reasoning behind each score.

On context sensitivity, I see potential for the tool to better reflect variations in system purpose or operational environment. While users can already input context, the workflow could be even more guided — for example, prompting users to frame assumptions or describe the intended use case more explicitly. That would help ensure the generated threats and risk assessments are more tailored to the specific system being modelled.

Overall, these are refinements to an already strong foundation. The structure and automation are well thought out; adding greater transparency and guided context input would make the outputs even more useful and defensible for practitioners.

Nil

Not sure yet

1) Current limitations of the tool is the lack of letting the user upload more documents. If the user can do that the result will be better.

2) The backend foundation LLM models use free tier API. Having a paid API to better online LLM models will improve its accuracy.

There are no particular challenge.

During the generation of the system model, there is a comment line that need removing.
The free tier of the LLMs limit the usage

1. Threat model will be good to reference back to the architecture and mark where will spoofing happen, where will DOS happen n etc.
2. Attack path is a bit hard to read. The diagram is too small, when i downloaded it, it didn't give me the diagram.
3. Under Analysis, it will be good for the model to detect the attack feasibility based on the system exposure in the architecture diagram (may be request for inventory list to show the OS version), instead of asking user to select a value.
4. Will be good to have a summary report?

a bit slow when generating the attack paths

To further enhance the tool's effectiveness, it is important to incorporate a feedback loop that allows users to input details of mitigation controls currently in place. This mechanism would enable continuous updating of the risk profile, ensuring that both existing and newly implemented controls are properly considered in risk assessments. By capturing real-time information on mitigation measures, stakeholders can make more dynamic and accurate decisions regarding risk prioritisation and resource allocation.

Q8. What improvements would you suggest to enhance the tool's usefulness and reliability?

It would be useful to take into account actual risk and vulnerability data from scanning results and asset databases, to be able to factor in the real-life applicability of attack paths and probabilities more accurately, e.g. whether specific assets and their versions are susceptible to various attack scenarios, instead of just theoretically possible. This would help make the user make actual remediation prioritization decisions more quickly.

Improve visibility and assurance Target System Architecture/Design

1. Ability to ingest from various data sources: asset management tool, ACL list, etc.
2. "Publish" the combined system architecture/design in various views/focus to aid user to review accuracy, before "approval" of the system design.
3. Process for multiple stakeholders to review and approve the system architecture/design.
4. Ability to develop initial system architecture from project conversations and whiteboard sketches.

Improve Trustworthiness

1. Parts/Information which can be deterministically obtained should be obtained via automation and explained/notified to the user.
2. LLMs are useful in some areas of the process, highlight where LLMs are used or LLM-assisted process, then allow or focus the user to review the accuracy of the output.

Other applications

1. Modelling of impact during failure of specific controls

More accurate and concise description for the uploaded architecture. Higher confidence of generating the right threats for the architecture.

Integrate with MITRE ATT&CK and DEF3ND.

It would be helpful if the tool could show more clearly how its conclusions are derived — for instance, a short rationale or reference for each DREAD or STRIDE output. Even something as simple as “based on this data flow or component relationship” would help users trace how the analysis was formed. That transparency builds trust and makes the results easier to validate or refine later.

A guided context input step would also be valuable. Prompts that nudge users to describe the system’s purpose, operating assumptions, or known constraints could make the generated threats and risk scores more accurate. It’s often this operational context that determines whether a threat is theoretical or genuinely high-risk.

Lastly, it might be worth exploring a way for users to fine-tune or override certain assumptions. For example, being able to adjust the perceived impact or exploitability after reviewing the DREAD results would give practitioners more control while still leveraging the automation.

Overall, I think the direction is spot-on. The tool already saves time and helps structure assessments. These small additions would make it more transparent, adaptable, and aligned with how practitioners reason through real-world systems.

Nil

Dunno

As answered in the previous question.

Generating Threat Risk Assessment (TRA), and security requirement as part of secure by design in SDLC.

Ability to export the analyses in report format or xls for offline visualisation

same as Q7

more choice of models

Additionally, integrating the input of identified threat actors as part of the assessment process would significantly strengthen the tool's analytical capabilities. By allowing users to specify known or anticipated threat actors relevant to their environment, the tool can tailor its threat modelling and risk evaluation to reflect real-world adversaries and tactics. This targeted approach not only enhances the accuracy of risk assessments but also ensures that mitigation strategies are aligned with the most pertinent threat scenarios facing the organisation.

Q9. Is there anything else you would like to share about your experience with the tool?

Overall, I think it is an excellent idea and effort. Truth be told, while I know this is theoretically possible, seeing the tool actually in action with reasonably good output has helped triggered further thoughts on how the tool can be used in different circumstances. I would be keen to explore these further.

There had been tools that perform threat modelling and risk qualification. There are also attempts to use AI to help obtain the system architecture/design. There are also tools that support risk management. It will be great if the tool can do all three.

Good Concept! This is very useful for us as Security Architects when we are doing threat modelling and risk assessment.

This tool addresses one of the major pain-points of end-user enterprises. Would eagerly await its full-fledged completion and perhaps commercialisation.

I say this half-jokingly — but if tools like this keep improving, we might all have to evolve from consultants to curators of good AI! Jokes aside, I actually see this as something that refines our work rather than replaces it. It speeds up the early analysis, reduces the manual frustration, and lets practitioners focus on the parts that really need human judgment.

It might also be useful if the tool could suggest typical use cases or prompt users with questions along the way — for example, “is this system Internet-facing?” or “does this component handle safety-critical functions?” That kind of guidance would make the outputs more tailored and also help users think more critically about their own system context.

Nil

Dunno

Make be the tool can produce some charts i.e. spider web chart to better visualise the outcome.

While there are concepts to develop such tool in the industry, I thought that the design of this tool allows different usage, which enables different personas to fulfill their work.

The diagram uploaded by me was a different sample set and the analysis done by the tool does aligned with our real life analysis. The key weakness is still the 5G sensors, even using DLT. This shows the high accuracy level of the tool.

good initiatives. it will definitely be very helpful if it can generate threats relating to the solution design, residual risk and recommendation actions for risk treatment.

NA

NIL